

Password Sprays & Token Plays: The Art of Staying Secure in Microsoft Entra





Thomas Naunheim

Cyber Security Architect @glueckkanja AG
Microsoft MVP (Identity & Access, Cloud Security)

Lives in Koblenz/Lahnstein, Germany



cloud-architekt.net



Naunheim.cloud



thomasnaunheim



Thomas_Live



Eric Woodruff

Chief Identity Architect @Semperis
Microsoft MVP (Identity & Access)

Lives in Schenectady, NY, USA



ericonidentity.com



ericonidentity.com



[ericonidentity](https://ericonidentity.com)



[ericonidentity](https://ericonidentity.com)



Identity is (still) under attack...

600 million

identity attacks
per day...

Microsoft Entra data,
[Microsoft Digital Defense
Report 2024](#)

99%

are password
attacks.

Microsoft Entra data,
[Microsoft Digital Defense
Report 2024](#)

111%

increase in token
replay attacks.

Microsoft Entra data, [How to
break the token theft cyber
attack chain](#), 2024.

146%

rise in AiTM
phishing attacks.

Microsoft Entra data,
[Microsoft Digital Defense
Report 2024](#)



Agenda

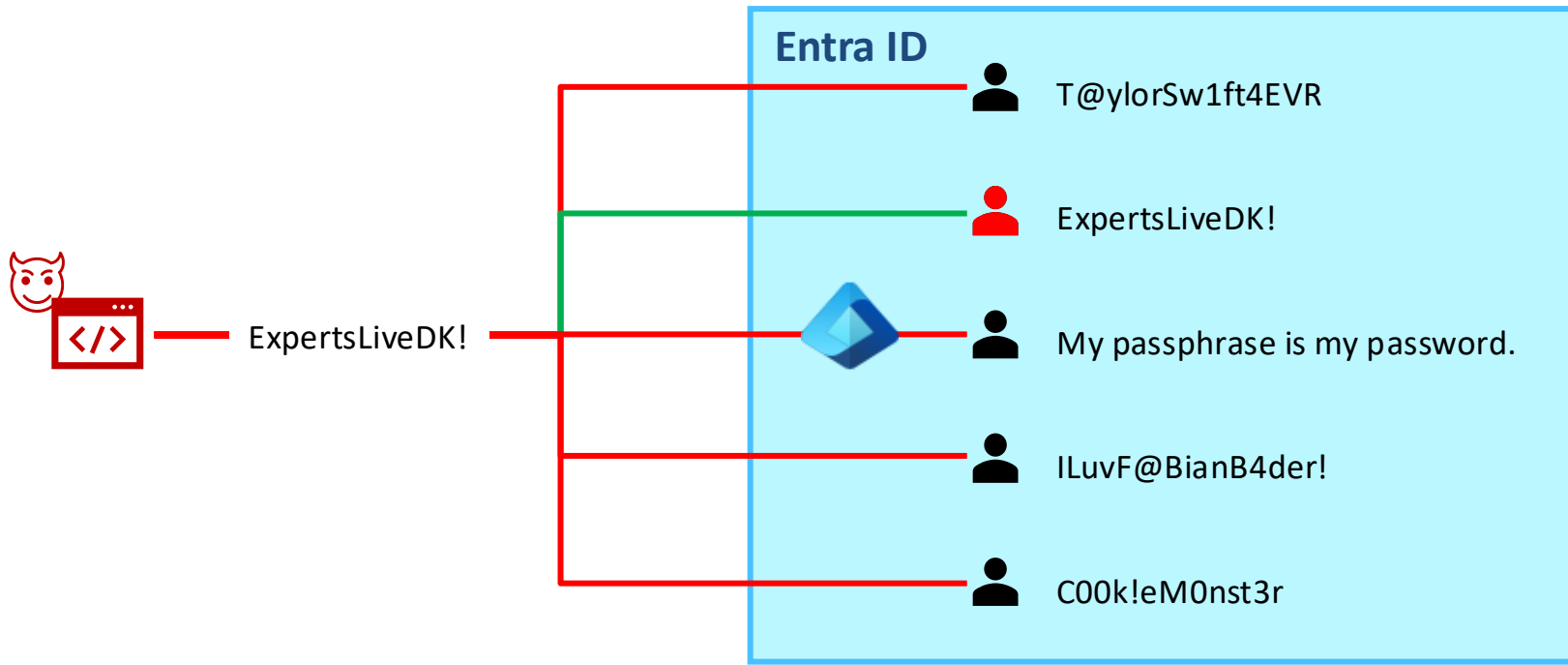
- Password-based attacks
- Token theft & replay
- Abusing privileges of OAuth2 applications
- Mitigation

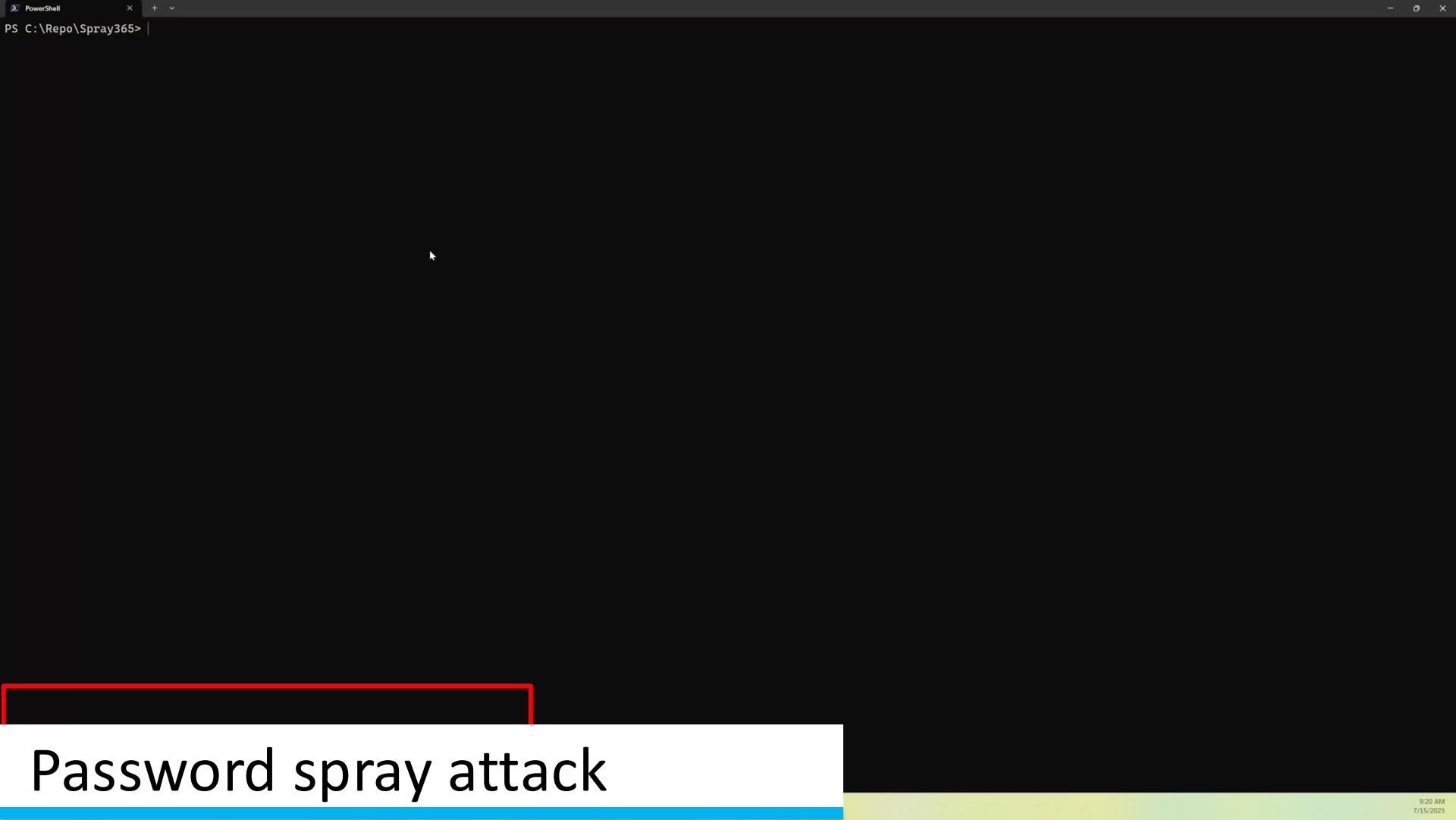
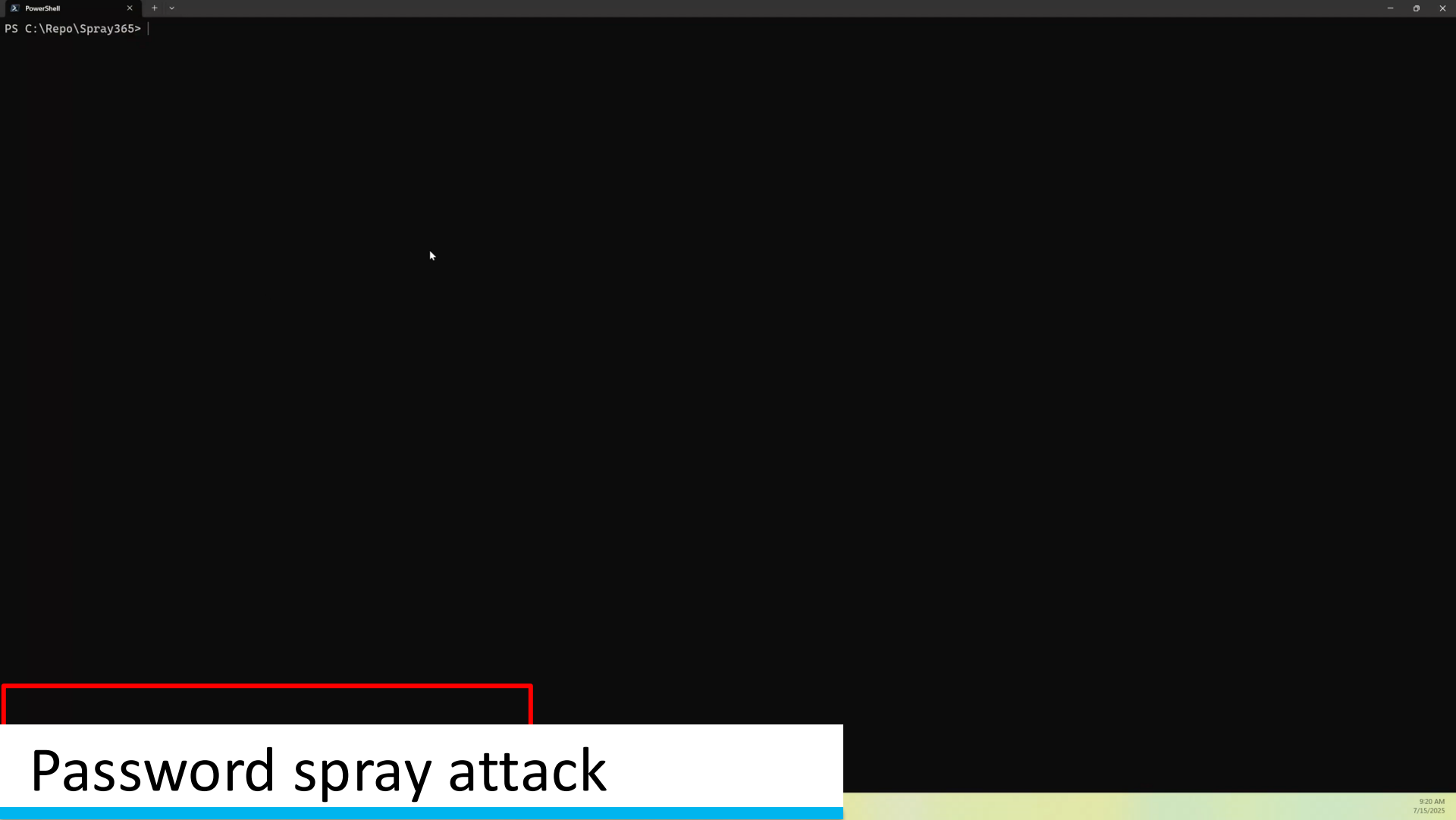


Password-based attacks



Overview of password spray attacks





Password spray attack



Always MFA? Find your single factor auth...

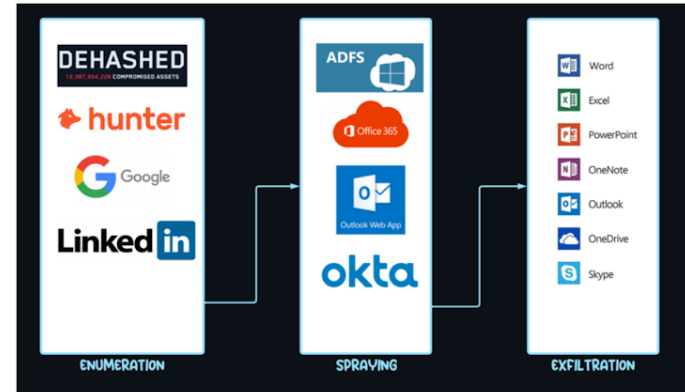
- Exclusion for (trusted) locations
- Service accounts and service principals
- SaaS applications
 - Local user accounts
 - Multiple identity providers

Are password spray attacks still a risk?

Over 80,000 Microsoft Entra ID Accounts Targeted Using Open-Source TeamFiltration Tool

Jun 12, 2025 Ravie Lakshmanan

The UNK_SneakyStrike activity has been described as "large-scale user enumeration and password spraying attempts," with the unauthorized access efforts occurring in "highly concentrated bursts" targeting several users within a single cloud environment. This is followed by a lull that lasts for four to five days.



Password spray protection in Entra ID

January 2025

General Availability - Real-time Password Spray Detection in Microsoft Entra ID Protection

A password spray attack is where multiple identities are attacked using common passwords in a unified brute force manner. The risk detection is triggered when an account's password is valid and has an attempted sign in. This detection signals that the user's password was correctly identified through a password spray attack, not that the attacker was able to access any resources.

- Calculated in real-time or offline
- License requirement: Microsoft Entra ID P2
- [Tips for investigating password spray detections.](#)

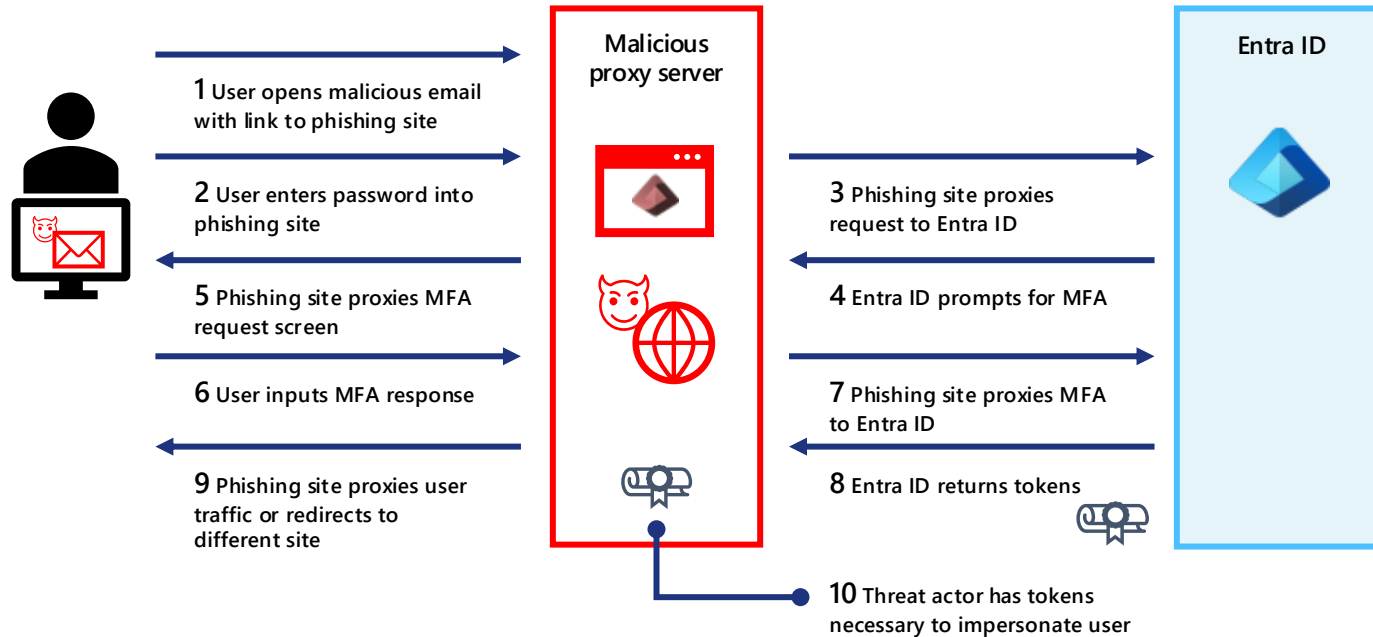
Risk Detection Details

 User's risk report  User's sign-ins  User's risky sign-ins  Linked risky sign-in  User's risk detections	
Detection type	Password spray ⓘ
Risk state	Confirmed compromised
Risk level	High
Risk detail	M365D admin dismissed detection
Attack type(s)	Brute Force: Password Spraying, Brute Force: Password Guessing
Source	Identity Protection
Detection timing	Offline
Activity	Sign-in
Detection time	9/4/2025, 10:26 AM
Detection last updated	9/5/2025, 4:14 PM
Token issuer type	Microsoft Entra ID
Sign-in time	9/3/2025, 3:17 AM
IP address	
Sign-in location	Washington, Virginia, US
Sign-in client	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36 Edg/139.0.0.0 OS/10.0.26100
Sign-in request id	564a6409-6ad5-4215-8308-19f928731b00
Sign-in correlation id	01990d26-0289-7ebd-a587-a4a419f5f57d



Token theft & replay

Overview of attacker in-the-middle



```
Administrator: PowerShell
PS C:\dev\evilginx2> .\build\evilginx.exe -p ./phishlets -t ./redirectors
```

Attacker-in-the-middle (AiTM)



AiTM attack disruption in Defender XDR

High Resolved u101@a.alpineskihouse.com BEC Fraud Credential Phish AiTM attack Attack Disruption AlpineSkiHouse SAPClient

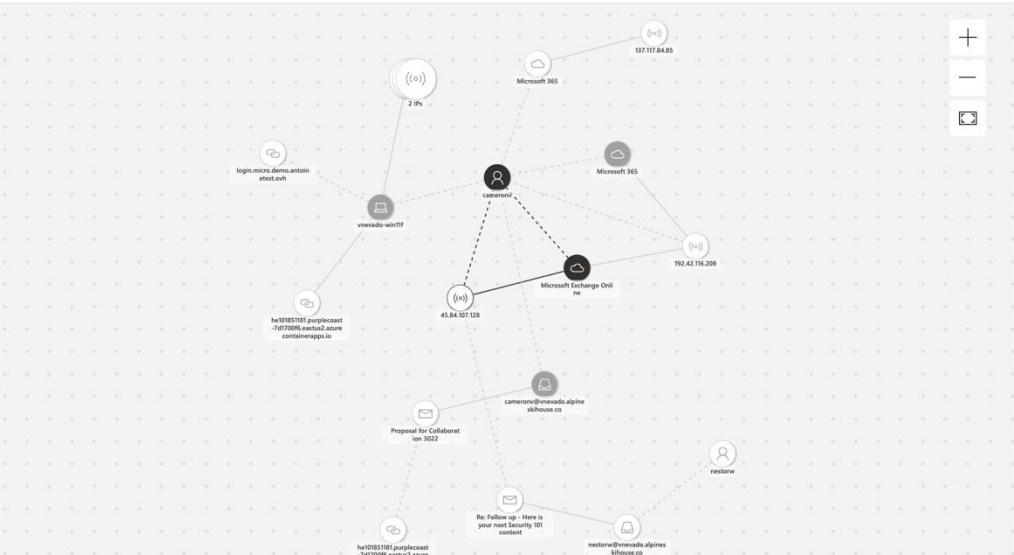
Attention! Attack disruption initiated multiple response actions. For more details, go to the [Action center](#).

Attack story Alerts (16) Assets (5) Investigations (0) Evidence and Response (20) Recommended actions (22) Summary Similar incidents (0)

Play attack story Unpin all Show all

- Mar 10, 2025 2:28 PM Resolved
Risky sign-in after clicking a possible AiTM phishing URL
Cameron V
- Mar 10, 2025 2:29 PM Resolved
Activity from a Tor IP address
Cameron V
- Mar 10, 2025 2:29 PM Resolved
Compromised user account in a recognized attack pattern
Cameron V
- Mar 10, 2025 2:31 PM Resolved
Suspicious Outlook rules
Cameron V
- Mar 10, 2025 2:31 PM Resolved
BEC financial fraud
Cameron V

Incident graph Layout Group similar nodes



Attack disruption

Automated response took place.

Disruption incident summary and impact

Attacker leveraged 1 compromised accounts.

Accounts

Contained 1

View actions in action center

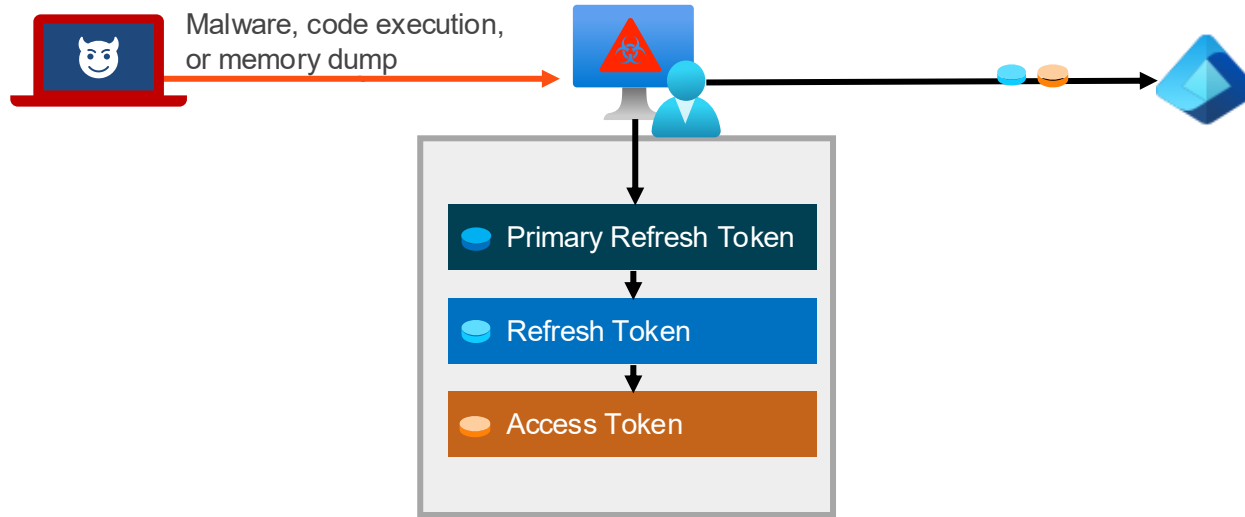
RECOMMENDATIONS

Phishing Incident response playbook

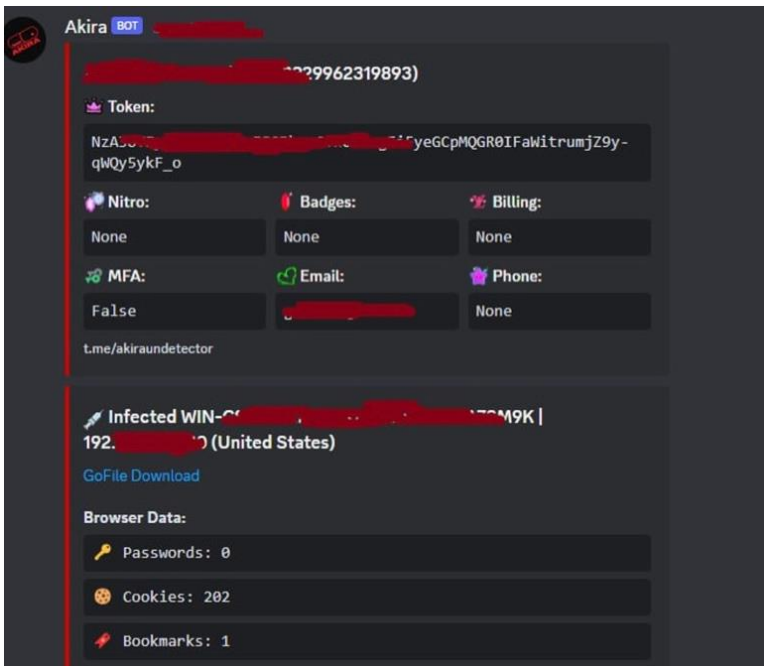
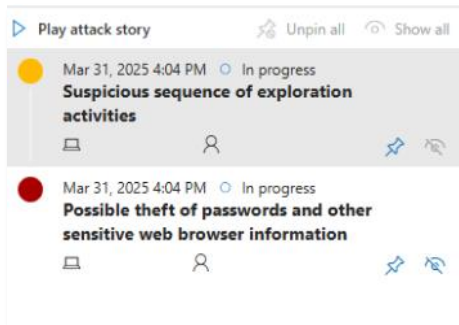
View phishing investigation and response recommended steps for this incident

Open phishing playbook

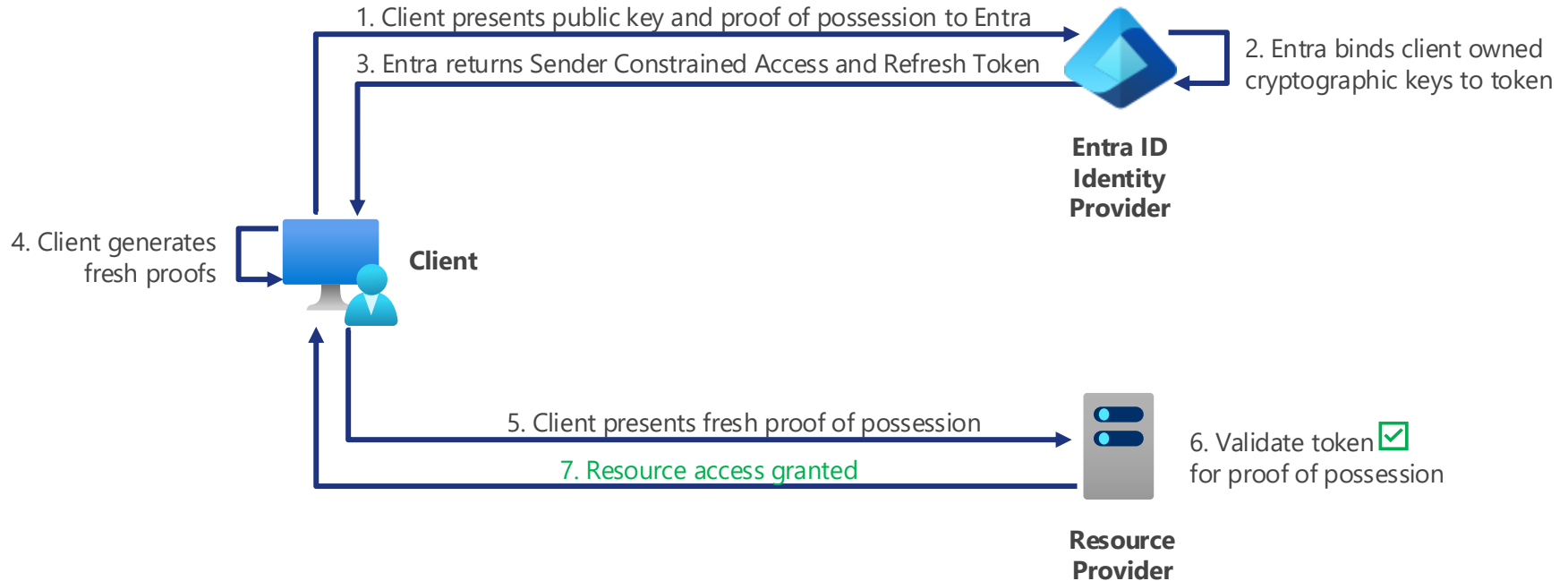
Exfiltrate tokens from Entra ID joined devices



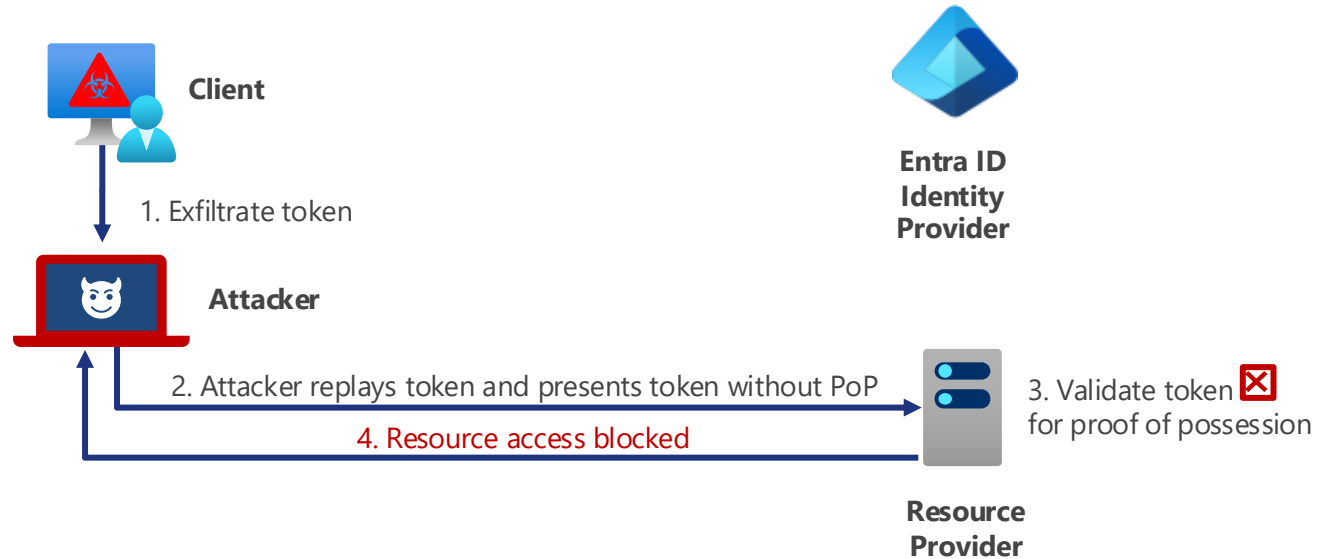
Real world story: Akira Stealer



Mitigation by token binding



Mitigation by token binding





...did you say cookies?



```
C:\WINDOWS\system32\cmd. x + v
Microsoft Windows [Version 10.0.26100.4652]
(c) Microsoft Corporation. All rights reserved.

C:\Users\AdeleVance>dsregcmd /status

+-----+
| Device State |
+-----+

        AzureAdJoined : YES
    EnterpriseJoined : NO
        DomainJoined : NO
    Virtual Desktop : NOT SET
        Device Name : DESKTOP-1NS51H1

+-----+
| Device Details |
+-----+

        DeviceId : 7e27c2f6-3f52-4d90-ac8c-35ad1998dce7
        Thumbprint : 1322844BF6D2509EFAF743CC9D84BD70BEB4E0E
DeviceCertificateValidity : [ 2025-07-16 08:18:39.000 UTC -- 2035-07-16 08:48:39.000 UTC ]
        KeyContainerId : 976b97a2-30a5-4c85-89e3-209b8c0cb4f0
        KeyProvider : Microsoft Platform Crypto Provider
        TpmProtected : YES
        DeviceAuthStatus : SUCCESS

+-----+
| Tenant Details |
+-----+
```

Session cookie replay

Using Cookie Bite PoC by Varonis

Victim

7a-94c0-df49ff2f2331/oauth2/authorize

Microsoft Windows [Version 10.0.26100.4656]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Thomas>dsregcmd /status

```
+-----+  
| Device State |  
+-----+
```

```
AzureAdJoined : NO  
EnterpriseJoined : NO  
DomainJoined : NO  
Virtual Desktop : NOT SET  
Device Name : clpen2-vm
```

```
+-----+  
| User State |  
+-----+
```

```
NgcSet : NO  
WorkplaceJoined : NO  
WamDefaultSet : NO
```

```
+-----+  
| SSO State |  
+-----+
```

```
AzureAdPrt : NO  
AzureAdPrtAuthority : NO  
EnterprisePrt : NO  
EnterprisePrtAuthority : NO
```

Session cookie replay

Using Cookie Bite PoC by Varonis

Attacker



ENG
DE



7:18 AM
7/22/2025

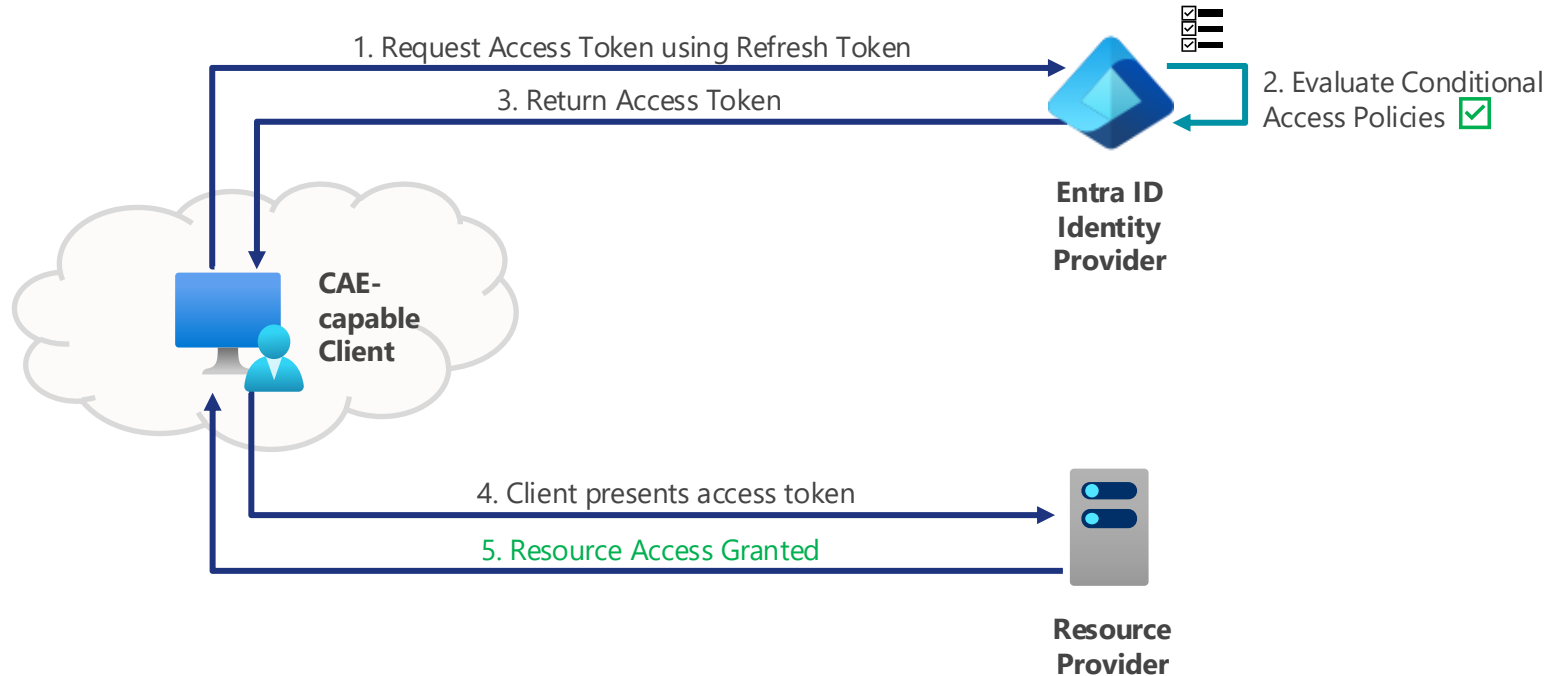


Sign-in logs from victim vs. attacker

AppDisplayName	OfficeHome	OfficeHome
ClientAppUsed	Browser	Browser
BrowserDetails	Chrome 138.0.0	Chrome 138.0.0
Location	DE	US
DeviceTrustType	Azure AD joined	Azure AD joined
IsCompliant	true	true
IPAddress	87.163.7.44	132.196.242.136
UserAgent	Mozilla/5.0 (Windows NT 10.0; Win64; x64)	Mozilla/5.0 (Windows NT 10.0; Win64; x64)
Grant Controls ↑↓ Result ↑↓		Grant Controls ↑↓ Result ↑↓
Require multifactor authentication		Success
Require compliant device		Success

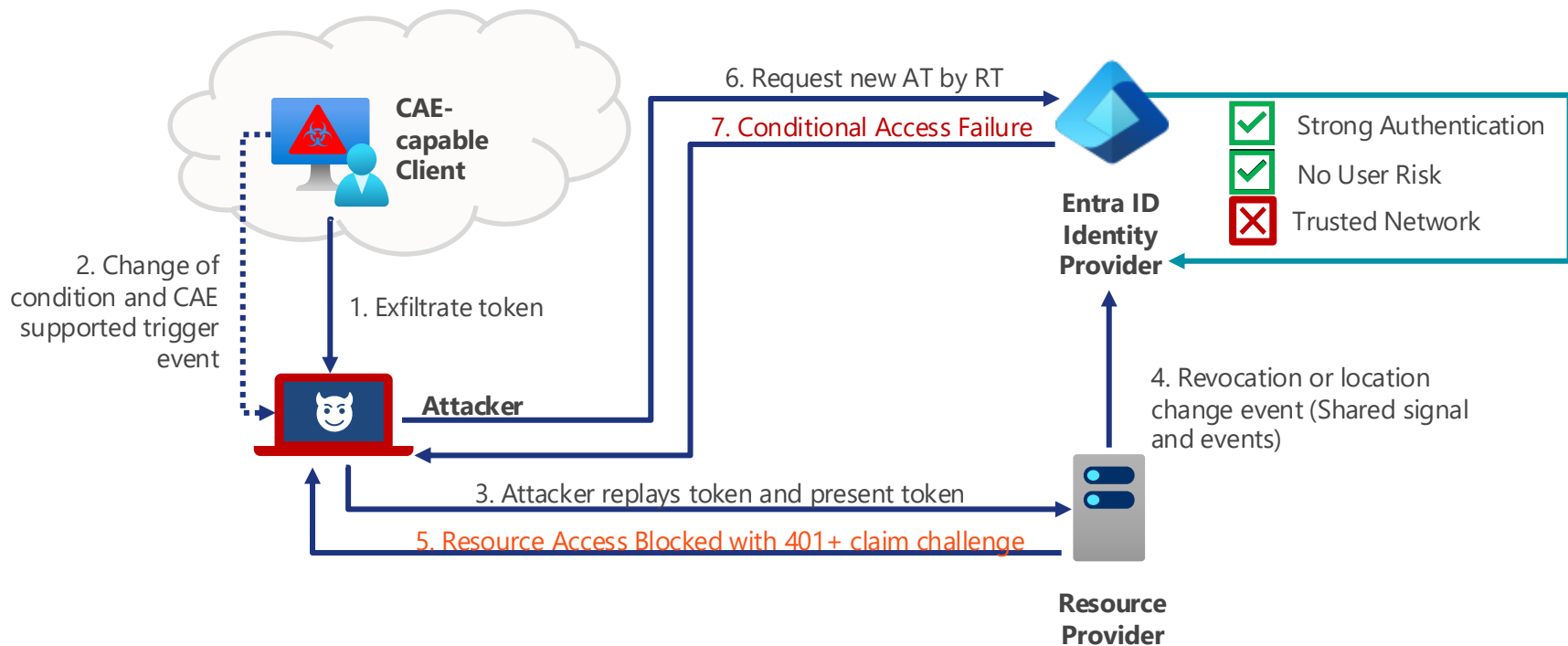


Token acquisition using Refresh Token

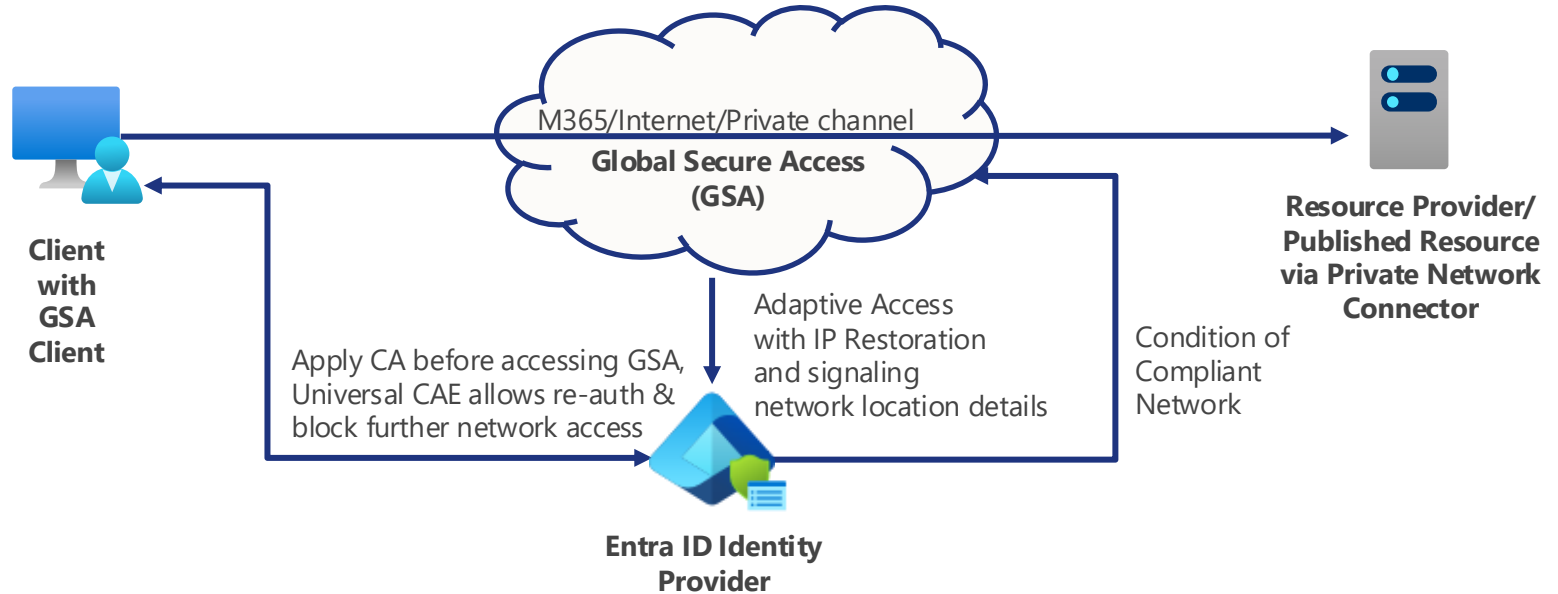




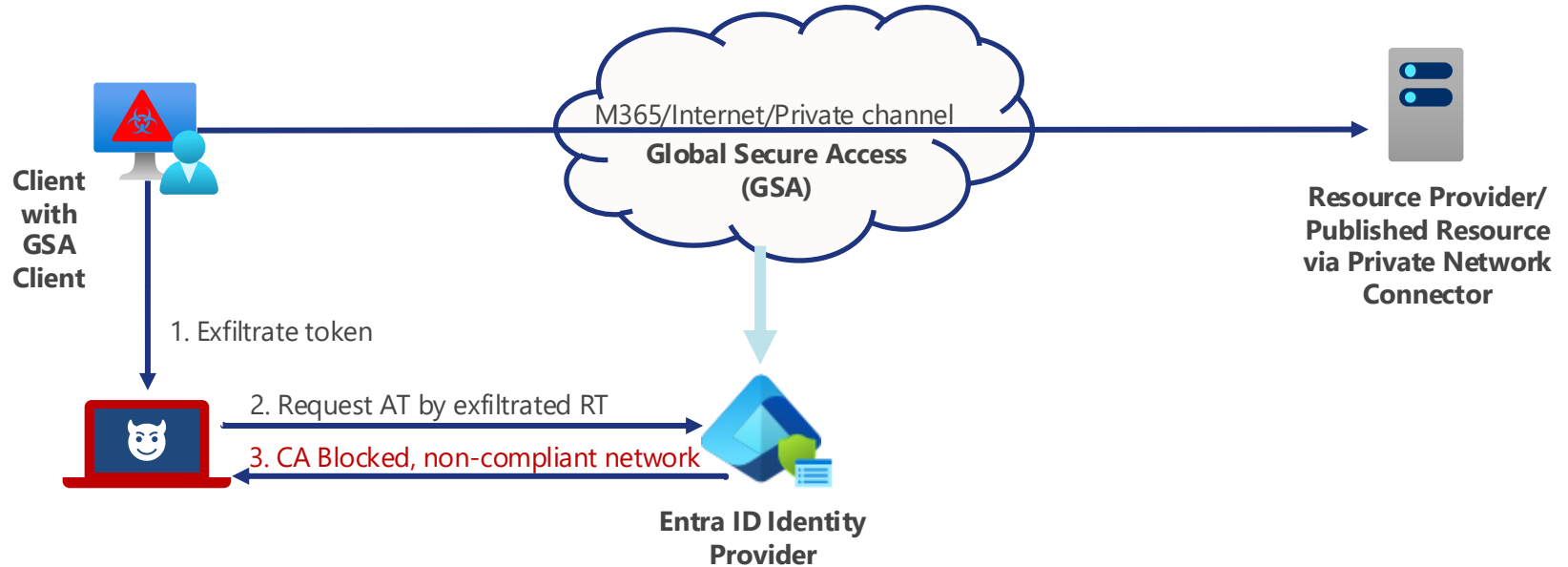
Continuous Access Evaluation token revocation



Mitigation by compliant (GSA) network



Mitigation by compliant (GSA) network





Abusing privileges of OAuth applications



Changes in user consent

Microsoft Secure Future Initiative (SFI)

Require admin
consent for third-
party apps accessing
files and sites

Users allowing third-party apps to access file and site content can lead to overexposure of an organization's content. **Requiring admins to consent** to this access can help reduce overexposure. With this change, Microsoft managed **App Consent Policies** will be enabled, and users will be unable to consent to third party applications accessing their files and sites by default. Instead, they can request administrators to consent on their behalf. To configure admin consent, follow instructions here: [Configuring the Admin Consent workflow](#). Customers who have already blocked user consent, turned on our previously recommended consent settings, or applied custom user consent settings will not be affected by this change. Admins can also configure granular app access policies, such as limiting user access to the application for specific users or groups. Learn more [here](#).

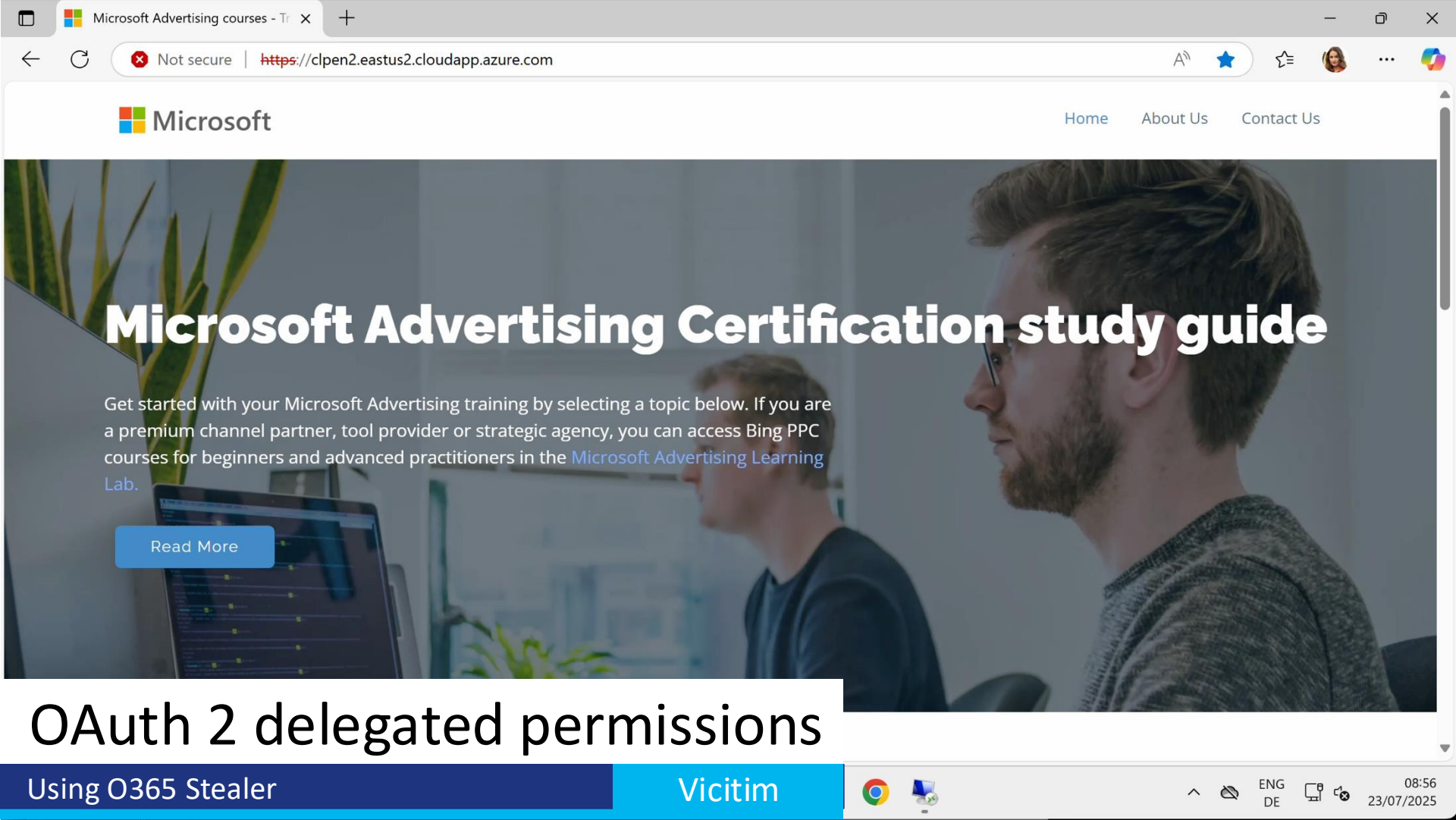


Who has admin consent permission?

Granting tenant-wide admin consent requires you to sign in as a user that is authorized to consent on behalf of the organization.

To grant tenant-wide admin consent, you need:

- A Microsoft Entra user account with one of the following roles:
 - Privileged Role Administrator, for granting consent for apps requesting any permission, for any API.
 - Cloud Application Administrator or Application Administrator, for granting consent for apps requesting any permission for any API, *except* Microsoft Graph app roles (application permissions).
 - A custom directory role that includes the [permission to grant permissions to applications](#), for the permissions required by the application.

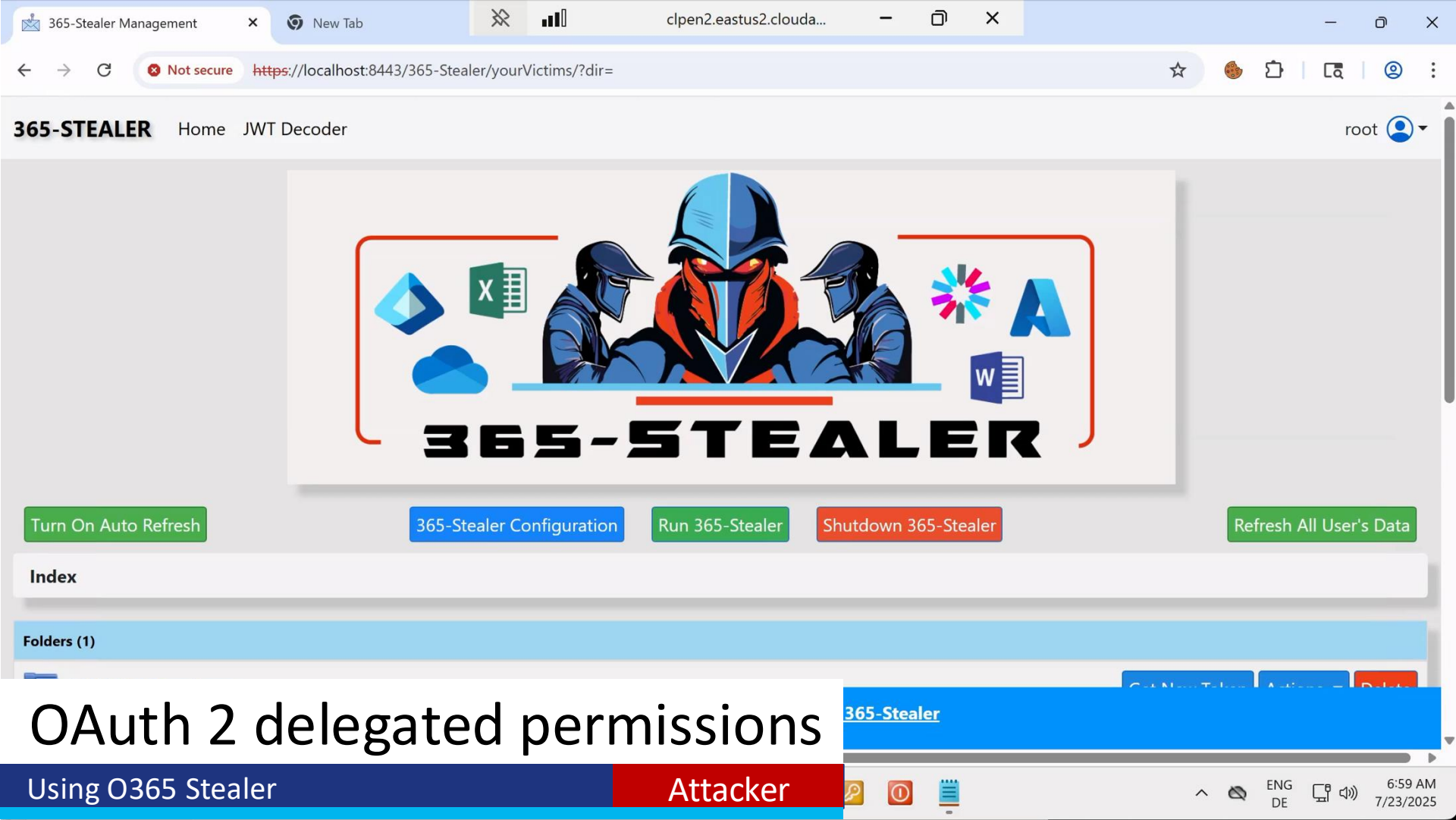


Microsoft Advertising Certification study guide

Get started with your Microsoft Advertising training by selecting a topic below. If you are a premium channel partner, tool provider or strategic agency, you can access Bing PPC courses for beginners and advanced practitioners in the [Microsoft Advertising Learning Lab](#).

Read More

OAuth 2 delegated permissions



365-STEALER Home JWT Decoder

root



Turn On Auto Refresh 365-Stealer Configuration Run 365-Stealer Shutdown 365-Stealer Refresh All User's Data

Index

Folders (1)

OAuth 2 delegated permissions

Using O365 Stealer Attacker

365-Stealer

ENG DE 6:59 AM 7/23/2025

Detection in M365 Defender

Compromised user account used to create a malicious OAuth application (attack ...

High | Resolved | u2330@ash.alpineskihouse.co | Critical asset | OAuth App Abuse | Attack Disruption

Copilot Manage incident Tasks ...

Attention! Attack disruption initiated a disable app action on a rogue OAuth app. For more details go to the [Action center](#).

Attack story Alerts (12) Assets (4) Investigations (0) Evidence and Response (17) Summary Similar incidents (0)

Play attack story

Unpin all

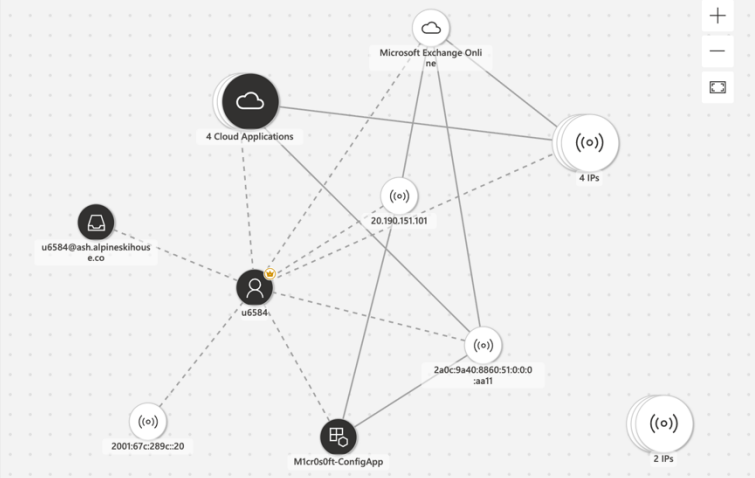
Show all

Incident graph

Layout

Group similar nodes

- Aug 22, 2025 7:42 AM Resolved
Malicious OAuth application registration by a compromised user
Abbi Montf... M1cr0s0ft-Conf...
- Aug 22, 2025 7:42 AM Resolved
Suspicious OAuth app registered through Azure CLI or PowerShell
Abbi Montfuledda
- Aug 22, 2025 7:42 AM Resolved
Suspicious OAuth app registration
Abbi Montfuledda
- Aug 22, 2025 7:42 AM Resolved
Risky user updated an app that accessed Email and performed Email activity through Graph API
Abbi Montfuledda
- Aug 22, 2025 7:45 AM Resolved
Suspicious inbox rule created by an OAuth app
Abbi Montfuledda



RELATED THREATS

Activity Profile: OAuth apps used in BEC and phishing

48 impacted assets

[View threat analytics report](#)

Threat Overview Profile: Cloud identity abuse

29 impacted assets

[View threat analytics report](#)

Incident details

Assigned to
u2330@ash.alpineskihouse.co

Incident ID
18046

Classification

Categories



Mitigation

A cartoon illustration of a game show set. Three contestants are seated at blue podiums. On the left is Eric, a bald man with a large red beard and a blue t-shirt. In the center is Thomas, a man with dark hair, glasses, and a grey t-shirt. On the right is Clippy, a white paperclip character with a face, arms, and legs, standing on a small base. The background features a blue grid pattern and a sign that says "CLIPPY" in the top right corner.

Eric

Thomas

Clippy

JEOPARDY!

Identity Security Edition

User Mitigation

Authentication Methods and Credentials	Advanced policies to protect sensitive access	Zero Trust signals	ITDR and Identity Security Posture	Device Compliance and Endpoint Security
Stronger AD password policy	Restrict use of device code flow	Risk-based Conditional Access Policies	Restrict user consent and enable admin approval	Require device state or compliance in CA baseline
Banned password protection	Restrict access from unmanaged devices by Session Policy (CAE Trigger)	No Location-based CA Exclusions	Avoid delegation of Application Admin and Ownership	Require TPM for Windows Hello and Secure Enclave for macOS
Adoption of Passwordless Authentication	Defender for Cloud Apps in combination with Edge MAM	Implement compliant network checks as condition in CA and take benefit of Universal CAE	Track exposed token and session cookies in Exposure Management	Enable Defender EDR capabilities
Require Phishing-resistant Authentication	Implement authentication context for sensitive actions	Access to Cloud Apps and On-Premises Resources by Global Secure Access	Adopt detection and hunting for unusual activities in post-authentication	Device compliance in combination with requiring low machine risk score
User doesn't know their password (SCRIL in AD)	Implement Token Protection for applicable cloud applications	Enable strictly enforcement of CAE for applicable applications	Automated incident response playbook to revoke tokens for compromised identities	Windows Enrollment attestation and monitor browser extension in Defender TVM

User Mitigation

Foundational

Authentication Methods and Credentials	Advanced policies to protect sensitive access	Zero Trust signals	ITDR and Identity Security Posture	Device Compliance and Endpoint Security
Stronger AD password policy	Restrict use of device code flow	Risk-based Conditional Access Policies	Restrict user consent and enable admin approval	Require device state or compliance in CA baseline
Banned password protection	Restrict access from unmanaged devices by Session Policy (CAE Trigger)	No Location-based CA Exclusions	Avoid delegation of Application Admin and Ownership	Require TPM for Windows Hello and Secure Enclave for macOS
Adoption of Passwordless Authentication	Defender for Cloud Apps in combination with Edge MAM	Implement compliant network checks as condition in CA and take benefit of Universal CAE	Track exposed token and session cookies in Exposure Management	Enable Defender EDR capabilities
Require Phishing-resistant Authentication	Implement authentication context for sensitive actions	Access to Cloud Apps and On-Premises Resources by Global Secure Access	Adopt detection and hunting for unusual activities in post-authentication	Device compliance in combination with requiring low machine risk score
User doesn't know their password (SCRIL in AD)	Implement Token Protection for applicable cloud applications	Enable strictly enforcement of CAE for applicable applications	Automated incident response playbook to revoke tokens for compromised identities	Windows Enrollment attestation and monitor browser extension in Defender TVM

User Mitigation Intermediate

Authentication Methods and Credentials	Advanced policies to protect sensitive access	Zero Trust signals	ITDR and Identity Security Posture	Device Compliance and Endpoint Security
Stronger AD password policy	Restrict use of device code flow	Risk-based Conditional Access Policies	Restrict user consent and enable admin approval	Require device state or compliance in CA baseline
Banned password protection	Restrict access from unmanaged devices by Session Policy (CAE Trigger)	No Location-based CA Exclusions	Avoid delegation of Application Admin and Ownership	Require TPM for Windows Hello and Secure Enclave for macOS
Adoption of Passwordless Authentication	Defender for Cloud Apps in combination with Edge MAM	Implement compliant network checks as condition in CA and take benefit of Universal CAE	Track exposed token and session cookies in Exposure Management	Enable Defender EDR capabilities
Require Phishing-resistant Authentication	Implement authentication context for sensitive actions	Access to Cloud Apps and On-Premises Resources by Global Secure Access	Adopt detection and hunting for unusual activities in post-authentication	Device compliance in combination with requiring low machine risk score
User doesn't know their password (SCRIL in AD)	Implement Token Protection for applicable cloud applications	Enable strictly enforcement of CAE for applicable applications	Automated incident response playbook to revoke tokens for compromised identities	Windows Enrollment attestation and monitor browser extension in Defender TVM

User Mitigation Mature

Authentication Methods and Credentials	Advanced policies to protect sensitive access	Zero Trust signals	ITDR and Identity Security Posture	Device Compliance and Endpoint Security
Stronger AD password policy	Restrict use of device code flow	Risk-based Conditional Access Policies	Restrict user consent and enable admin approval	Require device state or compliance in CA baseline
Banned password protection	Restrict access from unmanaged devices by Session Policy (CAE Trigger)	No Location-based CA Exclusions	Avoid delegation of Application Admin and Ownership	Require TPM for Windows Hello and Secure Enclave for macOS
Adoption of Passwordless Authentication	Defender for Cloud Apps in combination with Edge MAM	Implement compliant network checks as condition in CA and take benefit of Universal CAE	Track exposed token and session cookies in Exposure Management	Enable Defender EDR capabilities
Require Phishing-resistant Authentication	Implement authentication context for sensitive actions	Access to Cloud Apps and On-Premises Resources by Global Secure Access	Adopt detection and hunting for unusual activities in post-authentication	Device compliance in combination with requiring low machine risk score
User doesn't know their password (SCRIL in AD)	Implement Token Protection for applicable cloud applications	Enable strictly enforcement of CAE for applicable applications	Automated incident response playbook to revoke tokens for compromised identities	Windows Enrollment attestation and monitor browser extension in Defender TVM

User Mitigation Progressive

Authentication Methods and Credentials	Advanced policies to protect sensitive access	Zero Trust signals	ITDR and Identity Security Posture	Device Compliance and Endpoint Security
Stronger AD password policy	Restrict use of device code flow	Risk-based Conditional Access Policies	Restrict user consent and enable admin approval	Require device state or compliance in CA baseline
Banned password protection	Restrict access from unmanaged devices by Session Policy (CAE Trigger)	No Location-based CA Exclusions	Avoid delegation of Application Admin and Ownership	Require TPM for Windows Hello and Secure Enclave for macOS
Adoption of Passwordless Authentication	Defender for Cloud Apps in combination with Edge MAM	Implement compliant network checks as condition in CA and take benefit of Universal CAE	Track exposed token and session cookies in Exposure Management	Enable Defender EDR capabilities
Require Phishing-resistant Authentication	Implement authentication context for sensitive actions	Access to Cloud Apps and On-Premises Resources by Global Secure Access	Adopt detection and hunting for unusual activities in post-authentication	Device compliance in combination with requiring low machine risk score
User doesn't know their password (SCRL in AD)	Implement Token Protection for applicable cloud applications	Enable strictly enforcement of CAE for applicable applications	Automated incident response playbook to revoke tokens for compromised identities	Windows Enrollment attestation and monitor browser extension in Defender TVM



THANK YOU TO OUR AMAZING SPONSORS !

glueckkanja

robopack
empowered by SOFTWARE
CENTRAL

nerdio

W

Continue

veeam

VARONIS

eido

Admin By Request
ZERO TRUST PLATFORM

Lenovo

dynatrace

VirtualMetric

Red Hat

Arkimentum

semperis

DanofficeIT

EPIC FUSION
BRING IT ALL TOGETHER

Recast

twoday

European
Power Platform
Conference
COPENHAGEN 29 JUNE - 02 JULY 2026

inforcer

APENTO

TRUESEC

Surveil

GLOBE SYSTEMS

control UP

PATCH
MY PC

JN DATA
WE ARE ON

systemcenterdudes

EasyEntra

Microsoft

Implora.io

Yealink

TD SYNnex

TOKEN
token2.swiss

Cloud Factory

GLOBETEAM

NORDSTERN

VENZO
a valantic company

FEITIAN
WE BUILD SECURITY

identity stack

2LINKIT